

Cybersecurity Labs

Universidade do Minho

2025/2026

M4 - Wazuh

59782 — Afonso Alves Leite de Sousa — Mestrado em Cibersegurança
60309 — Tomás Afonso Brito Oliveira — Mestrado em Cibersegurança
59803 — Vítor Hugo Abreu Gonçalves — Mestrado em Cibersegurança

Grupo 9

Cenário

Usámos o Wazuh, uma plataforma open-source de SIEM e XDR. O nosso laboratório consistia num servidor central (Manager/Dashboard) e numa máquina “vítima” a correr um servidor Apache, monitorizada por um agente do Wazuh.

Lab 1

Antes de virem os ataques, precisávamos de conhecer o nosso ambiente. A primeira coisa que fizemos foi configurar o File Integrity Monitoring (FIM). Alterámos o ficheiro de configuração do agente (ossec.conf) para monitorizar a pasta /var/www/html do Apache. Escrevemos regras básicas de detecção, como uma regra de frequência que disparava se alguém fizesse vários erros 404 (página não encontrada) em poucos segundos, simulando reconhecimento de rede:

```
<!-- — File integrity monitoring ————— -->

<syscheck>
  <disabled>no</disabled>
  <frequency>120</frequency>
  <scan_on_start>yes</scan_on_start>
  <alert_new_files>yes</alert_new_files>

  # New
  <directories report_changes="yes" realtime="yes">/var/www/html</directories>
  # End

  <directories check_all="yes" report_changes="yes" realtime="yes">/etc</directories>
```

Configuração do agente (ossec.conf) para monitorizar a pasta /var/www/html

FIM: Recent events

Time ↓	Path	Action	Rule description	Rule Lev...	Rule Id
May 25, 2026 @ 13:21:04.224	/var/www/html/index.html	modified	Integrity checksum changed.	7	550

Alerta de modificação do Ficheiro index.html

timestamp	agent.name	rule.description	rule.level	rule.id
May 25, 2026 @ 13:28:03.8...	wazuh.manager	Wazuh server started.	3	502
May 25, 2026 @ 13:28:01.9...	victim	lab1 demo: someone hit /lab1-demo	7	100199

Alerta do 100199 (Nível 7) regra específica para se alguém tentar acessar o URL lab1 demo

May 25, 2026 @ 18:05:28.4...	victim	Possible Local File Inclusion attempt	10	100200
------------------------------	--------	---------------------------------------	----	--------

Alerta Da Regra 100200 (Nível 10) Possível tentativa de Local File Inclusion

timestamp	agent.name	rule.description	rule.level	rule.id
May 25, 2026 @ 18:10:38.7...	victim	Web server 400 error code.	5	31101
May 25, 2026 @ 18:10:38.7...	victim	Web server 400 error code.	5	31101
May 25, 2026 @ 18:10:38.7...	victim	Web Reconnaissance: Multiple 404 errors from same IP	10	100201
May 25, 2026 @ 18:10:38.7...	victim	Web server 400 error code.	5	31101
May 25, 2026 @ 18:10:38.7...	victim	Web server 400 error code.	5	31101
May 25, 2026 @ 18:10:38.7...	victim	Web server 400 error code.	5	31101
May 25, 2026 @ 18:10:38.6...	victim	Web server 400 error code.	5	31101
May 25, 2026 @ 18:10:38.6...	victim	Web server 400 error code.	5	31101
May 25, 2026 @ 18:10:38.6...	victim	Web server 400 error code.	5	31101
May 25, 2026 @ 18:10:38.6...	victim	Web server 400 error code.	5	31101

Alerta Da Regra 100201 (Nível 10) e sinaliza Reconhecimento Web

```
<rule id="100202" level="0">
  <if_sid>31101</if_sid>
  <url>^/status$</url>
  <description>Suppress 404 for /status health-check path</description>
</rule>
```

Regra para falsos positivos garantindo que verificações de rotina (health-checks) não geram ruído no Threat Hunting.

```
<rule id="100201" level="10" frequency="8" timeframe="30">
  <if_matched_sid>31101</if_matched_sid>
  <description>Web Reconnaissance: Multiple 404 errors from same IP</description>
</rule>
```

Regra de frequência que simula reconhecimento de rede.

Lab 2

Na segunda fase, avaliamos as falhas do nosso sistema. O Wazuh faz uma análise passiva: ele lê os pacotes instalados e cruza-os com bases de dados de vulnerabilidades (CVEs). Descobrimos cerca de 53 vulnerabilidades, mas destacamos as mais críticas: o Log4Shell (CVE-2021-44228), o Shellshock (CVE-2014-6271) e um Apache Overflow (CVE-2026-28780).

Para provar que o SIEM estava a funcionar, testámos ativamente alguns destes ataques via terminal usando comandos curl. Lançámos ataques de SQL Injection, XSS e Shellshock. Foi aqui que vimos o framework MITRE ATT&CK: o Wazuh também categoriza a tática, o que nos ajuda a perceber a intenção do atacante.

Passive vulnerability detection

Log4Shell

- **CVE ID, CVSS e Severidade:** CVE-2021-44228 | CVSS: 10.0 | Severidade: Critical.
- **O que permite fazer (Impacto):** Permite a Execução de Código Remoto (RCE - Remote Code Execution). O atacante só precisa de enviar uma mensagem manipulada nos logs para forçar o servidor a executar código malicioso.
- **Pacote e Versão Afetada:** liblog4j2-java (versão 2.14.0-1).

- **Existe Exploit Público:** Sim. É uma das vulnerabilidades mais exploradas e documentadas.

Shellshock

- **CVE ID, CVSS e Severidade:** CVE-2014-6271 | CVSS: 9.8 | Severidade: Critical.
- **O que permite fazer (Impacto):** Também permite Execução de Código Remoto (RCE). O atacante consegue executar comandos de sistema injetando código no final de variáveis de ambiente (frequentemente explorado através de cabeçalhos HTTP em servidores web antigos).
- **Pacote e Versão Afetada:** bash (versão 4.3-14ubuntu1.7).
- **Existe Exploit Público:** Sim. É um ataque muito conhecido, com milhares de scripts de exploração disponíveis publicamente.

Apache Heap-based Buffer Overflow

- **CVE ID, CVSS e Severidade:** CVE-2026-28780 | CVSS: 9.8 | Severidade: Critical.
- **O que permite fazer (Impacto):** É uma falha de Buffer Overflow (Transbordo de Dados) na memória. Permite a um atacante escrever dados fora do espaço alocado, o que geralmente causa o bloqueio do servidor (Denial of Service) ou usado para Execução de Código Remoto.
- **Pacote e Versão Afetada:** apache2 e derivados (apache2-bin, apache2-utils, apache2-data) na versão 2.4.52-1ubuntu4.19.
- **Existe Exploit Público:** Sendo um CVE datado de 2026 (criado especificamente para o cenário simulado deste laboratório), na vida real ainda não estaríamos em 2026. No entanto, no contexto deste laboratório, assume que sim, existe uma forma de o atacante se aproveitar disto.

Active attack simulation

1.
 - **Regra ID:** 31166
 - **Descrição:** Shellshock attack attempt
 - **Técnicas MITRE ATT&CK:** T1068 (Exploitation for Privilege Escalation) e T1190 (Exploit Public-Facing Application).
2.
 - **Regra ID:** 100175
 - **Descrição:** HTTP request: url contains a scripting expression pattern
 - **Técnica MITRE ATT&CK:** T1059.007 (JavaScript) / Tática: Execution.
3.
 - **Regra ID:** 31164
 - **Descrição:** SQL injection attempt.
 - **Técnica MITRE ATT&CK:** T1055 (Process Injection) e T1190 (Exploit Public-Facing Application).
4.
 - **Regra ID:** 100201
 - **Descrição:** Web Reconnaissance: Multiple 404 errors from same IP
 - **Técnica MITRE ATT&CK:** (Não tem, porque foi uma regra personalizada).

Connecting CVEs to techniques

- **Log4Shell (CVE-2021-44228) e Apache Heap-based Buffer Overflow (CVE-2026-28780):** A técnica MITRE associada é principalmente a T1190 (Exploit Public-Facing Application). Elas não apareceram na nossa vista MITRE porque não lançamos nenhum comando curl a simular estes ataques específicos.
- **Shellshock (CVE-2014-6271):** A técnica associada também é a T1190, além da T1068 (Exploitation for Privilege Escalation). Esta apareceu com sucesso no nosso dashboard porque nós disparámos ativamente o payload no terminal.
- **O que fazer para produzir um evento em falta:** Para gerar um alerta de uma vulnerabilidade que não tem correspondência MITRE visível, precisaríamos de duas coisas: primeiro, garantir que o Wazuh tem uma regra escrita para detetar a assinatura desse ataque (ou escrevermos nós uma customizada) e, segundo, lançar o exploit contra a máquina vítima.

Discussion: Passive vulnerability analysis

- **Passive vs network scanning:** O scan passivo do Wazuh olha para os pacotes instalados e cruza com a base de dados de CVEs sem tocar na rede. Isto apanha tudo o que está instalado, mas pode gerar falsos alarmes. Um network scanner testa ativamente as portas abertas, ele só apanha o que está exposto, mas garante que a falha é realmente alcançável, não mostrando pacotes ocultos e internos.
- **What the dashboard does not tell you:** A lista de CVEs apenas nos mostra o risco potencial. Para saber se estão a ser ativamente explorados neste momento, precisaríamos de olhar para os logs de rede, eventos de segurança (como os alertas do Threat Hunting) e comportamentos anómalos de processos (FIM).
- **Prioritisation:** O CVSS ajuda porque nos dá um valor matemático da gravidade da fraqueza. No entanto, um CVSS de 9.8 num pacote que está enterrado numa rede interna sem acesso pode ser menos urgente do que um CVSS de 7.5 no nosso servidor Apache público. Devemos priorizar sempre consoante a exposição à internet e a criticidade do sistema para o negócio.
- **A preview:** Tendo em conta a nossa análise, a previsão é que o atacante vai começar por usar o Apache Heap-based Buffer Overflow (CVE-2026-28780), tentar usar o Shellshock (CVE-2014-6271) para aceder à máquina, e possivelmente usar o Log4Shell (CVE-2021-44228) para escalar privilégios.

Discussion: Active attack detection

- **Technique vs vulnerability:** Um CVE descreve uma "falha" técnica no software. A técnica MITRE descreve uma "ação" ou comportamento do atacante. Trabalhar com tags MITRE permite a um analista ver a "história" (a Kill Chain) do ataque por exemplo, ver que o atacante passou de "Initial Access" para "Execution", em vez de apenas ler descrições isoladas de regras.
- **Coverage gaps:** O Shellshock teve correspondência MITRE. O Log4Shell e o Apache overflow não tiveram. Este gap significa que houve um lab-scope gap (não testámos ativamente essas falhas nesta fase).
- **False positive rate:** As regras de XSS e SQLi são acionadas por palavras-chave básicas (script, OR 1=1). Numa implementação real, para reduzir o ruído sem perder o sinal, escreveríamos regras de supressão (com nível 0) para ignorar os IPs dos nossos próprios scanners de vulnerabilidades autorizados, ou usamos regras de

frequência (como no Lab 1) para alertar apenas quando existem múltiplas tentativas num curto espaço de tempo.

Lab 3

No Lab 3, acordámos um contentor 'atacante' escondido que lançou um ataque real e automatizado contra a nossa máquina vítima, explorando algumas daquelas vulnerabilidades que tínhamos mapeado.

Passo 1: Silenciar o Ruído

O atacante estava a fazer um ataque de força bruta massivo ao portal de login e a gerar dezenas de erros 500 no Apache. Para conseguirmos ver os ataques críticos, escrevemos regras de nível 0 (supressão) para silenciar este ruído de fundo, sem apagar as regras originais.

Ruído do atacante:

- Regra 100163: HTTP: POST /login authentication failed (Nível 3)
- Regra 100165: CorpNet Portal: login failed for user... (Nível 3)
- Regra 31122: Web server 500 error code (Internal Error) (Nível 5)

Passo 2: Aumentar a Severidade e Categorizar

Com o lixo limpo. Vimos tentativas de Directory Traversal, injeção de JNDI (Log4Shell) e execução do pkexec (PwnKit). O problema é que estas regras originais tinham níveis muito baixos (nível 5 ou 6) e faltavam-lhes as tags do MITRE. Fomos ao código e subimos todas estas regras críticas para nível 12 e 13, adicionando as respetivas técnicas MITRE.

Regra 100120 & 100200 (Directory Traversal / LFI)

- **O que apanha:** Padrões codificados de ../ e tentativas de acesso ao /etc/passwd ou /etc/shadow.
- **CVE / MITRE:** MITRE T1190 (Exploit Public-Facing Application) ou T1083 (File Discovery).
- **Severidade:** Nível 6 para a 100120 e 10 para a 100200. Um analista trataria a 100200 como alta prioridade, mas a 100120 é muito baixa (deveria ser ≥ 10).
- **O que falta:** Ambas não têm a tag <mitre> no código original.

Regra 100130 (JNDI)

- **O que apanha:** A substring exata jndi: em qualquer log aplicacional.
- **CVE / MITRE:** Log4Shell (CVE-2021-44228). MITRE T1190.
- **Severidade:** Nível 6. Log4Shell é crítico. Deveria ser ≥ 12 .
- **O que falta:** Falta adicionar <mitre><id>T1190</id></mitre>.

Regra 100140 (pkexec)

- **O que apanha:** A presença da string pkexec num log de sistema.
- **CVE / MITRE:** Isto mapeia para uma famosa vulnerabilidade de elevação de privilégios chamada PwnKit (CVE-2021-4034). MITRE T1068 (Exploitation for Privilege Escalation).
- **Severidade:** Nível 5. Demasiado baixo para alguém tentar ganhar acesso root.
- **O que falta:** Falta a tag MITRE (T1068).

Regras 100160, 100162 e 100170 (Acesso a relatórios e criação de ficheiro TAR)

- **O que apanha:** Apanha um POST em /reports/submit, a criação de um ficheiro na pasta de relatórios e a execução do comando tar.
- **CVE / MITRE:** Indica um ataque de injeção de comandos. MITRE T1059 (Command and Scripting Interpreter).
- **Severidade:** Variam entre os níveis 3, 4 e 7. Isoladas são apenas eventos informativos, mas juntas representam um ataque severo.
- **O que falta:** Faltam as tags MITRE.

Regra 100150 (FIM passwd)

- **O que apanha:** O Wazuh detetou que o ficheiro /etc/passwd foi modificado.
- **CVE / MITRE:** O atacante conseguiu escalar privilégios e criar uma conta. MITRE T1098 (Account Manipulation).
- **Severidade:** Nível 8. Deve ser um alerta máximo (12 a 15).
- **O que falta:** Falta a tag MITRE no XML.

Passo 3: A Regra de Correlação

A parte mais importante foi o atacante escalar privilégios e alterar o ficheiro /etc/passwd. Para garantir que essa ação crítica seja vista, criámos uma Regra de Correlação de Nível 15 (o nível máximo). Esta regra dizia: se encontrar um exploit JNDI e, nos 5 minutos seguintes, o ficheiro de passwords for alterado... o sistema foi totalmente comprometido.

	May 26, 2026 @ 18:08:32.6...	victim	HTTP request: url contains a scripting expression pattern	12	100175
	May 26, 2026 @ 18:08:32.6...	victim	Suspicious URL access.	6	31516
	May 26, 2026 @ 18:08:29.5...	victim	CRITICAL: JNDI exploit followed by /etc/passwd modification. System Compromised!	15	100400
	May 26, 2026 @ 18:08:11.3...	victim	HTTP request: url contains a scripting expression pattern	12	100175
	May 26, 2026 @ 18:07:49.6...	victim	Application log line contains the substring 'jndi:'	13	100130

5. Conclusão: A História do Ataque (Reflection)

1. Reconstrução do Ataque

Com base nos logs limpos e nas regras melhoradas, é possível traçar a cronologia exata e os passos do atacante:

- 18:03:49 - Acesso Inicial: O atacante começou por tentar explorar o Shellshock (CVE-2014-6271) nos scripts CGI do servidor. Paralelamente, executou ataques de força bruta no portal de login (ruído que foi silenciado pelas regras de nível 0).

	May 26, 2026 @ 18:03:54.9...	victim	Shellshock attack attempt	6	31166
	May 26, 2026 @ 18:03:52.9...	victim	Shellshock attack attempt	6	31166
	May 26, 2026 @ 18:03:50.9...	victim	Shellshock attack attempt	6	31166
	May 26, 2026 @ 18:03:49.0...	victim	Shellshock attack attempt	6	31166

- 18:04:34 - Reconhecimento de Ficheiros: O atacante tentou explorar vulnerabilidades no Apache (CVE-2026-28780) usando Directory Traversal / LFI (Regra 100120) para tentar ler ficheiros sensíveis do sistema.

May 26, 2026 @ 18:04:59.5...	victim	Apache: Attempt to access forbidden file or directory.	5	30305
May 26, 2026 @ 18:04:59.5...	victim	Suspicious URL access.	6	31516
May 26, 2026 @ 18:04:41.5...	victim	HTTP request: url contains an encoded '.' segment	12	100120
May 26, 2026 @ 18:04:39.5...	victim	HTTP request: url contains an encoded '.' segment	12	100120
May 26, 2026 @ 18:04:37.5...	victim	HTTP request: url contains an encoded '.' segment	12	100120
May 26, 2026 @ 18:04:34.2...	victim	HTTP request: url contains an encoded '.' segment	12	100120
May 26, 2026 @ 18:04:30.2...	victim	HTTP request: url contains a scripting expression pattern	12	100175
May 26, 2026 @ 18:04:10.2...	victim	CorpNet Portal: login succeeded for user diana	5	100166
May 26, 2026 @ 18:04:10.2...	victim	HTTP: POST /login — authentication successful	5	100164

- 18:05:48 - Execução de Código (RCE): O atacante injetou um payload malicioso direcionado à biblioteca Log4j, explorando o Log4Shell (CVE-2021-44228). A regra 100130 disparou (nível 13), confirmando a execução de código remoto.

May 26, 2026 @ 18:05:52.2...	victim	Application log line contains the substring 'jndi:'	13	100130
May 26, 2026 @ 18:05:50.4...	victim	Application log line contains the substring 'jndi:'	13	100130
May 26, 2026 @ 18:05:50.3...	victim	Application log line contains the substring 'jndi:'	13	100130
May 26, 2026 @ 18:05:48.4...	victim	Application log line contains the substring 'jndi:'	13	100130
May 26, 2026 @ 18:05:48.2...	victim	Application log line contains the substring 'jndi:'	13	100130
May 26, 2026 @ 18:05:28.9...	victim	HTTP request: url contains a scripting expression pattern	12	100175
May 26, 2026 @ 18:05:16.8...	victim	Apache: Attempt to access forbidden file or directory.	5	30305
May 26, 2026 @ 18:05:16.8...	victim	Suspicious URL access.	6	31516
May 26, 2026 @ 18:05:12.8...	victim	CorpNet Portal: login succeeded for user admin	5	100166
May 26, 2026 @ 18:05:12.8...	victim	HTTP: POST /login — authentication successful	5	100164
May 26, 2026 @ 18:05:03.5...	victim	CorpNet Portal: login succeeded for user diana	5	100166
May 26, 2026 @ 18:05:03.5...	victim	HTTP: POST /login — authentication successful	5	100164

- 18:07:49 - Escalonamento de Privilégios: Já com acesso ao sistema, o atacante precisava de permissões de administrador. Explorou a falha no Polkit, o PwnKit (CVE-2021-4034), evidenciado pela execução suspeita do comando pkexec (Regra 100140 a nível 12).

May 26, 2026 @ 18:08:11.3...	victim	HTTP request: url contains a scripting expression pattern	12	100175
May 26, 2026 @ 18:07:49.6...	victim	Application log line contains the substring 'jndi:'	13	100130
May 26, 2026 @ 18:07:49.4...	victim	Application log line contains the substring 'jndi:'	13	100130
May 26, 2026 @ 18:07:49.3...	victim	System log: 'pkexec' substring observed	12	100140

- 18:08:29 - Persistência e Compromisso Total: Como prova final do domínio do sistema, o atacante modificou o ficheiro /etc/passwd para criar uma backdoor ou utilizador próprio. Isto ativou a nossa regra de correlação (Regra 100400, nível 15), cruzando o exploit JNDI anterior com a alteração do ficheiro, confirmando que o sistema foi totalmente comprometido.

May 26, 2026 @ 18:08:29.5...	victim	CRITICAL: JNDI exploit followed by /etc/passwd modification. System Compromised!	15	100400
------------------------------	--------	--	----	--------

2. Avaliação do Conjunto de Regras

- O que funcionou melhor: A regra de correlação (100400) forneceu um alerta importante crítico. Em vez de analisar eventos isolados, cruzou o vetor de entrada (Log4Shell) com o objetivo final (alteração de credenciais), eliminando qualquer dúvida de falso positivo.
- O ruído: As regras de erro 500 e tentativas falhadas de login criavam demasiada "fadiga de alertas". A criação de regras "filhas" de nível 0 foi essencial para permitir que os ataques reais se destacassem.
- Melhorias para Produção: Num ambiente real (SIEM em produção), o nível original das regras era baixo. A adição das tags MITRE ATT&CK também seria obrigatória para que a equipa de SOC pudesse mapear as táticas dos atacantes em relatórios globais.

Em conclusão, este laboratório provou que não basta instalar um SIEM. Ter uma lista de CVEs não nos diz se estamos a ser atacados. É preciso analisar ativamente o tráfego,

silenciar falsos positivos, e criar regras de correlação inteligentes baseadas no comportamento (MITRE) para transformar um mar de logs confusos numa ferramenta de defesa eficaz.